

GRACE CONNECT

Security Feature Review & Standard Privacy Policy

Prepared from the GitHub repository scan of Shamzbruv/Grace_Connect

Date: June 15, 2026

Important legal note

This document is a strong operational privacy-policy draft and technical security summary based on the repository reviewed. It is not legal advice. Before publishing the policy in an app store, website, or production app, a qualified attorney or data-protection professional should review it against the final production build, the actual hosting region, the churches using the app, and the jurisdictions where users will access the service.

1. Executive Summary

Grace Connect is a Flutter-based church and community management app. The repository identifies the app as a church management system and includes Supabase for authentication, database access, storage, realtime features, and session management. It also uses Firebase services for messaging, analytics-related infrastructure, Cloud Functions, and push notifications.

The app is not a simple member directory. It handles account creation, church membership, member roles, attendance and geofenced check-in, events, announcements, prayer requests, counseling requests, direct messages, study groups, testimonies, family connections, giving links, support tickets, notifications, media uploads, profile privacy controls, blocking, reporting, and administrative workflows.

Because the app processes personal data, religious/community participation data, location data, messages, support details, and potentially sensitive pastoral-care information, its privacy policy must be specific. A short generic privacy policy would not be enough for the current feature set.

2. Repository Scope Reviewed

Area	Finding
Application framework	Flutter / Dart mobile and web app
Primary backend	Supabase Auth, Postgres tables, Row Level Security, Storage, Realtime, RPC functions
Secondary cloud services	Firebase Core, Firebase Messaging, Firebase Analytics dependency, Firebase Cloud Functions
Key permission areas	Internet, location, background location, microphone/audio recording, notifications, foreground service, gallery/file access through pickers
Key app areas reviewed	Authentication, profile, privacy settings, attendance, direct messages, community feed, stories, study groups, prayer, counseling, events, announcements, giving, support, moderation, role management, audit logs, storage/media

3. Security Feature Scan

3.1 Authentication and session protection

- Primary authentication is handled through Supabase Auth. The app initializes Supabase with PKCE authentication flow and supports auth callback detection for web and mobile deep links.
- Email confirmation is enforced. New users are signed out immediately after signup so they cannot continue into the app without verifying the email address.
- Login checks whether a Supabase user is confirmed. If the email is not verified, the app signs the user out and offers to resend the verification email.
- Protected screens use an authentication gate that checks the active Supabase user/session and redirects users who are unauthenticated or unconfirmed.

- The app refreshes the Supabase session when the app resumes, reducing stale session problems and keeping profile/attendance state aligned.
- Password reset is done through Supabase email reset flow rather than exposing passwords in the app. The Remember Me feature stores the email address only, not the password.

3.2 Supabase Row Level Security and church isolation

- Supabase migrations enable row-level security on sensitive tables including users, direct messages, direct conversations, family relationships, study groups, group messages, user blocks, content reports, testimonies, and other feature tables.
- The app uses church isolation repeatedly. Many policies require the record church identifier to match the authenticated user's church context, preventing ordinary users from browsing records belonging to another church.
- User profile insert is limited to the authenticated user's own UID/id. This prevents users from inserting profiles for other users through normal client calls.
- Family relationship requests can be viewed only by the requester or related user and can only be created within the same church. Requests must be approved before family links are written to user profiles.
- Community likes, study group joins, event RSVPs, and similar state changes are handled through server-side RPC functions that check authentication and church membership before updating shared records.

3.3 Role-based access control and administrative separation

- The database defines role normalization and role-check functions so that roles such as Pastor, Senior Pastor, Church Admin, Secretary, Event Coordinator, Prayer Warrior, Counselor, Deacon, Elder, Treasurer, and others can be checked consistently.
- Event creation, updates, and deletion are limited to church staff roles. Regular members can RSVP but cannot manage events unless their role allows it.
- Prayer requests and counseling requests have different access models. Users can see their own requests, and church care/prayer leadership roles can view or update relevant requests for pastoral care.
- Audit logs are visible only to role managers in the same church. Role assignment RPC functions check the acting user's church, role, and target member's church before changing roles.
- Role changes are logged into audit_logs and, in later migration logic, can trigger notifications to the affected user.

3.4 Privacy and safety controls built into the product

- Users have profile privacy controls for private profile, contact information visibility, messaging permission, family-tree visibility, relationship-type visibility, and family link request permissions.
- Contact information can be set to church-only, visible to any Grace Connect member, or private. Private profile and contact visibility settings hide email and phone from other members in the app UI logic.
- Direct messaging respects user messaging preferences and block relationships. Conversation creation requires both members to be in the same church and both to allow messaging.

- Users can block other users. Blocked users cannot message or interact normally according to the database policies and UI settings.
- Users can report content with structured reasons such as harassment, hate speech, nudity/sexual content, violence/threats, scams, spam, misinformation, inappropriate language, impersonation, or other reason. Reports are visible to the reporter and approved church leaders.

3.5 Messaging, media, and vanishing-content controls

- Direct messages support text, images, video, audio/voice media, delivered timestamps, read timestamps, delete-for-me, delete-for-everyone by sender, and conversation hiding.
- Direct messages have a default expiration period of 30 days. Community posts also carry a 30-day expiration. Community stories expire after approximately 24 hours.
- Cleanup functions delete expired content and related media objects from Supabase Storage. Triggers attempt to remove storage files when related database records are deleted.
- Chat media upload is limited by MIME type and file size in the Supabase storage bucket configuration. Supported media includes common image, video, and audio formats.
- Important hardening note: the reviewed storage policy for chat media allows authenticated users broad read/upload/delete access to the chat media bucket. Before production launch, storage policies should be narrowed to object-owner or conversation-participant paths where possible.

3.6 Attendance, location, and anti-fraud checks

- The app uses device location to verify attendance when a church geofence and service schedule are configured.
- Location-based attendance requires location services and app permission. The app calculates distance from the church geofence and requires a dwell period, with a default of 10 minutes, before marking a user present.
- Attendance records include method, service, timestamp, present status, late status, minutes late, and service name. Duplicate attendance for the same user/service/day is checked before insertion.
- The app also supports remote attendance during active services, storing a reason, engagement answer, watched minutes when supplied, and a remote_verified status.
- Local dwell tracking is stored in device shared preferences using a user/service/date key, so the app can track whether the user stayed on property long enough to unlock attendance.

3.7 Notifications and secure push authorization

- Firebase Messaging is used for push notifications, with topic subscriptions by church and optional topics such as events, updates, devotionals, community, and prayers.
- When sending church-wide topic notifications, the app calls a Firebase Cloud Function with the Supabase access token. The function validates the token against Supabase, loads the user profile, checks that the topic matches the user's church, and verifies that the user has a role authorized to send announcements.
- In-app notifications are stored in Supabase and watched by user_id. The app supports unread counts and mark-as-read actions.

3.8 Support, device diagnostics, and operational records

- Support tickets collect issue type, app section, impact level, summary, description, user id, reporter email, church id, roles, app version, build number, device operating system, device model/brand/name where available, and optional image attachments.
- Support attachments are uploaded to a Supabase storage bucket and public URLs are generated. This is convenient, but it should be reviewed before production if screenshots may contain sensitive church, member, counseling, or account information.
- Role assignments and sensitive administrative actions are logged in audit logs where migrations implement logging. Audit logs should be retained separately from ordinary user content because they serve security and accountability purposes.

3.9 Giving and finance boundaries

- The app's Giving screen loads a church-configured SpurrOpen giving link and opens it in an external browser after a confirmation dialog. The repository does not show in-app card processing for donations.
- The finance service can store transaction records such as churchId, userId, userName, amount, type, category, description, date, and receipt URL when the finance feature is used.
- The privacy policy should clearly state that external giving/payment providers process payment information under their own terms, while Grace Connect may store giving links, transaction records, receipt URLs, and finance settings if enabled by the church.

4. Security Gaps and Production Hardening Recommendations

Area	Recommendation
Account deletion	The UI has a Delete Account option, but the current implementation signs the user out and comments that a secure Cloud Function or Supabase Edge Function is needed. Implement real deletion or deletion request workflow before store submission.
Google Play account deletion	Because the app allows account creation, Google Play requires users to be able to request account deletion from inside the app and from an external web resource. The privacy policy must explain retention and deletion clearly.
Storage bucket visibility	Profile avatars, chat media, and support attachments generate public URLs in reviewed code. Review whether media should be public, signed, path-restricted, or time-limited.
Chat media delete policy	The reviewed chat_media delete policy is broad for authenticated users. Narrow it to object owner, uploader, or message sender/participant logic.
Support attachment sensitivity	Support screenshots may include private messages, prayer/counseling information, phone numbers, or church details. Add warnings, scan/redaction guidance, and tighter storage policies.
Background location disclosure	The Android manifest requests background location. If this remains in production, the app needs a prominent in-app disclosure and consent before background location collection.

Payment provider disclosure	Since giving opens an external provider, the policy should state that payment data is handled by the external giving provider and link to that provider's privacy policy once confirmed.
Legacy Firebase/Firestore functions	Some Cloud Function logic still references Firestore users/churches while the main app uses Supabase. Remove or align legacy paths to avoid inconsistent role handling.
API key restrictions	Publishable keys and mobile API keys are expected in client apps, but Google Maps/API keys should be restricted by package name, SHA certificate, bundle ID, and allowed APIs.
Sensitive pastoral data retention	Prayer and counseling requests can be highly sensitive. Define church-level retention windows, access review, and pastoral confidentiality procedures.

5. Standard Privacy Policy for Grace Connect

Publishing instruction

Replace bracketed placeholders before publishing. The policy should be hosted on a public, non-geofenced, non-editable webpage and linked inside the app and in app-store listings. Do not publish only as a PDF if submitting to Google Play.

Privacy Policy

Effective Date: June 15, 2026

App Name: Grace Connect

Operator / Developer: [Grace Connect / iCreate Solutions / Church organization / Legal entity name]

Privacy Contact: [privacy email address]

1. Who we are

Grace Connect is a church and faith-community application designed to help churches, ministries, leaders, and members manage church life in one place. The app may be used for account creation, church membership, member profiles, attendance, events, announcements, prayer requests, counseling requests, direct messages, Bible study groups, testimonies, community posts, family connections, giving links, notifications, support, and church administration.

Depending on how Grace Connect is deployed, the organization operating the app, the developer, and each participating church may have different responsibilities for the information collected through the app. For member, attendance, prayer, counseling, event, giving, and church administration records, the relevant church may act as the data controller or primary decision-maker for how that data is used. Supabase, Firebase/Google, email providers, map providers, storage providers, notification providers, and payment/giving providers generally act as service providers or processors that help operate the app.

2. Scope of this policy

This Privacy Policy explains how Grace Connect collects, uses, stores, shares, protects, and deletes personal information when you use the app, website, backend services, support features, or related services.

This policy applies to members, visitors, church leaders, ministry leaders, administrators, volunteers, support users, and any person whose information is entered into Grace Connect by a user or church.

This policy does not replace any separate privacy notice issued by your church, external giving provider, livestream provider, Google, Supabase, Firebase, or any other third-party service linked from the app.

3. Information we collect

Account and authentication information: name, email address, phone number, password authentication handled by Supabase Auth, user ID, email verification status, session tokens, account status, sign-in method, password reset activity, and account metadata needed to create and secure your account.

Church membership information: church ID, church name, church place identifier, church role, ministry role, privileges, join date, approval status, transfer requests, membership status, and information needed to place a member in the correct church community.

Profile information: full name, display name, phone number, email address, address, parish, city, profile photo, cover photo, biography, social links, WhatsApp link, account preferences, privacy settings, and contact visibility settings.

Family connection information: family relationship requests, requester and related member IDs, relationship type, status, notes, response date, family tree visibility, relationship labels, spouse, parent, child, or other approved connection fields where enabled.

Community and communication content: community posts, comments, likes, stories, captions, media URLs, testimonies, testimony reactions, group messages, direct messages, direct message media, voice/audio messages, read status, delivered status, deleted-for-me status, conversation membership, and related timestamps.

Prayer and pastoral-care information: prayer request titles, details, privacy setting, church ID, requester ID, prayer status, prayer-team actions, counseling request category, urgency, details, status, assigned care/counseling roles, and related notifications. This type of information may be sensitive and should be submitted only when you are comfortable sharing it with the relevant church leadership or care team.

Attendance and location information: device location permission state, church geofence location, distance from church geofence, attendance timestamp, service ID, service name, method of check-in, present/absent status, late status, minutes late, remote attendance reason, engagement answer, watched minutes, and local dwell-time records used to verify that a member remained on church property long enough to check in.

Events, announcements, and ministry information: event title, date, time, location, RSVP/attendee lists, organizer ID, announcements, notification metadata, ministry membership, study-group membership, study-group settings, and ministry-related records.

Notifications and device messaging data: Firebase Cloud Messaging token, notification topic subscriptions, notification preferences, notification titles and bodies, route metadata, read/unread status, and in-app notification history.

Giving and finance information: church giving URL, giving provider settings, finance settings, transaction records where enabled, amount, type, category, description, date, user ID, user name, church ID, receipt URL, and external-giving status. Payment-card or bank information entered on an external giving page is processed by that external provider under its own privacy policy and terms.

Support and diagnostic information: support ticket ID, issue type, app section, impact level, summary, description, reporter email, user ID, church ID, roles, app version, build number, operating system, device model, brand or name, screenshots, attachments, support email status, and support communication content.

Audio, image, video, and file information: profile pictures, cover photos, chat images, chat videos, voice messages, audio files, story media, community media, support attachments, filenames, file paths, public URLs or storage references, MIME type, and duration where applicable.

Usage, analytics, and technical information: app version, build number, device information, logs, crash or diagnostic information, IP addresses and user agents processed by third-party services, feature usage, notification activity, and data needed for security, abuse prevention, debugging, and service improvement.

4. How we use information

We use personal information to create and secure accounts, verify email addresses, authenticate users, prevent unauthorized access, provide church-specific access, and maintain active sessions.

We use membership and profile information to show the correct church dashboard, member directory, roles, ministries, family connections, privacy settings, contact preferences, and church-specific features.

We use location and attendance information to confirm whether a member is physically present at a configured church location during an active service, to prevent duplicate check-ins, to mark attendance, and to support church attendance reporting.

We use prayer, counseling, and care-related information to route requests to authorized church leaders, pastors, prayer teams, counselors, deacons, elders, or other care-team roles according to the church's configuration.

We use communications and community content to deliver direct messages, group messages, posts, stories, testimonies, likes, reactions, comments, reports, moderation actions, and member interactions.

We use notifications to send service reminders, church updates, direct message alerts, prayer updates, event notices, announcements, role updates, and other app-related communications.

We use support and diagnostic information to troubleshoot problems, investigate reports, improve reliability, respond to requests, detect abuse, and communicate with users about support tickets.

We use finance and giving information to show church giving options, record finance transactions where enabled, display giving summaries to authorized users, and help churches manage giving-related settings.

We use administrative and audit information to manage roles, enforce permissions, investigate security issues, maintain accountability, comply with legal obligations, and protect users, churches, and the service.

5. Supabase authentication, database, storage, and realtime processing

Grace Connect uses Supabase as a primary backend for authentication, database storage, file storage, realtime subscriptions, and server-side database functions. Supabase Auth processes account credentials, authentication sessions, email verification, password reset links, and user identity data.

Grace Connect stores app records in Supabase tables, including users, churches, attendance, notifications, direct messages, study groups, prayer requests, counseling requests, events, reports, blocks, family relationships, support tickets, finance records, and other records needed by the app.

Grace Connect uses Supabase Row Level Security and role-based policies to limit what authenticated users can read or change. These policies are designed to restrict ordinary members to their own church, their own profile, their own conversations, and other records they are authorized to access.

Files such as profile photos, chat media, support attachments, and other media may be stored in Supabase Storage. Some media features generate public URLs. Do not upload confidential information unless you understand who may be able to view it through the app or generated links.

Supabase may process and store information in countries outside your own country. Supabase acts as a service provider/processor for app data stored by Grace Connect, while the app operator and/or participating church decides the purposes for using that data.

6. Firebase, Google services, and push notifications

Grace Connect uses Firebase and Google services for features such as push notifications, Cloud Functions, topic messaging, and related app infrastructure. Firebase Cloud Messaging may process device tokens, notification topics, notification content, and technical data needed to deliver notifications.

When a church-wide notification is sent, Grace Connect may validate the sender's Supabase session and church role before sending the push notification. Notification data may include the notification title, body, topic, route, and type.

Google Analytics for Firebase or related Google services may process usage and device information if enabled in the production build. Analytics data is used to understand app performance, feature usage, and reliability, not to sell personal information.

Google Maps or location services may be used to support church geofence setup, attendance verification, and map-based features. Your device operating system may ask for location permission before location information is accessed.

7. Location and background location

Grace Connect may request precise location, approximate location, and background location permissions where supported by the operating system. Location is used primarily for attendance and geofence verification.

When auto check-in is enabled, the app may monitor whether your device enters or remains within the configured church geofence during an active service. The app checks distance from the church location, applies a dwell-time requirement, and records attendance only when the required conditions are met.

You can control location permissions through your device settings. If location permission is denied, attendance geofence features may not work. You may still use other app features that do not require location.

Grace Connect should present a clear in-app disclosure before collecting location in the background. If you do not see that disclosure in the production app, contact the app operator before enabling background location.

8. Photos, camera/gallery, microphone, and media

Grace Connect may request access to your photos, gallery, files, camera, or microphone/audio recording depending on the feature you use. Examples include profile photo upload, cover photo upload, chat media, voice messages, community stories, support screenshots, and file attachments.

You choose whether to upload media. Uploaded media may be visible to other users depending on the feature, audience setting, group membership, direct conversation membership, church settings, privacy settings, or generated public URL.

Voice messages and audio files may include your voice and background sounds. Do not record or upload audio unless you have permission from everyone whose voice or information may be included.

9. Prayer, counseling, testimony, and religious/community data

Grace Connect is built for churches and faith communities. As a result, some information you enter may reveal religious involvement, church membership, spiritual needs, prayer requests, counseling needs, family relationships, attendance patterns, or other sensitive community information.

Prayer requests may be public to your church, private to you and authorized prayer/care roles, or governed by your church's configuration. Counseling requests are intended for authorized pastoral-care roles, but they are still digital records and should not be used for emergency services.

If you are experiencing an emergency or immediate risk of harm, contact local emergency services or trusted local support instead of relying on the app.

Church leaders and app administrators should treat prayer and counseling data with confidentiality and should limit access to people with a legitimate pastoral or operational need.

10. Messaging, community content, reporting, and blocking

Grace Connect allows members to communicate through direct messages, study-group messages, community posts, stories, testimonies, comments, likes, and reactions. Content you submit may be visible to other users according to the feature and your privacy settings.

Direct messages are intended for the participants in the conversation, but app administrators or service providers may access records where necessary for security, legal compliance, abuse investigation, support, or system maintenance.

Users may block other users and report content. Reports may include the reported content, reported user ID, reason, description, metadata, reporter ID, and church ID. Reports may be reviewed by authorized church leaders or app administrators.

Grace Connect may remove, restrict, or preserve content if necessary to enforce rules, protect users, investigate abuse, respond to legal requests, or maintain service integrity.

11. Giving, donations, and external payment providers

Grace Connect may provide a Giving feature that opens your church's configured external giving page, such as SpurrOpen or another provider, in an external browser. The external provider, not Grace Connect, generally processes payment-card, bank, or donation transaction data entered on that external page.

Grace Connect may store the church's giving link, finance settings, transaction records, receipt URLs, amounts, categories, dates, user names, user IDs, and other finance-related records if the church uses those finance features.

Before making a payment or donation, review the external provider's privacy policy, refund policy, terms of service, and security notices. Grace Connect is not responsible for the privacy practices of external giving providers.

12. How we share information

With your church and authorized church leaders: information may be shared with your church, pastors, church administrators, ministry leaders, prayer team, counseling team, finance team, or other authorized roles based on the feature and permissions.

With other app users: profile details, posts, comments, stories, testimonies, reactions, events, family links, messages, and contact information may be visible to other users depending on your settings, church membership, group membership, feature design, and content you choose to share.

With service providers: we share or process information through Supabase, Firebase/Google, email providers, notification services, map services, storage services, support systems, analytics services, and other vendors that help operate the app.

With external giving/payment providers: if you open an external giving page, that provider receives the information you enter directly and may receive technical data from your browser/device.

For legal, safety, and security reasons: we may disclose information if required by law, legal process, church safeguarding obligations, security investigation, fraud prevention, emergency protection, or to enforce our terms and policies.

Business or organizational changes: if Grace Connect or a participating church changes operator, merges, transfers assets, or changes service providers, data may be transferred as part of that change with appropriate protections where required.

13. Your privacy choices and controls

You can update certain profile information in Account Settings, including your name, phone number, and profile photo.

You can use Privacy & Safety settings to manage private profile status, contact visibility, member messages, family tree visibility, relationship-type visibility, and family link request permissions.

You can block or unblock users and report content through moderation features where available.

You can turn off notification categories through app settings or device notification settings. Some service, security, or account messages may still be sent where needed.

You can disable location permissions through your device settings. Doing so may prevent geofence attendance and auto check-in from functioning.

You can request access, correction, deletion, or export of your information by contacting the privacy contact listed in this policy or your church administrator.

14. Data retention

Account and profile records are generally kept while your account remains active or as long as needed to provide the app, comply with legal obligations, resolve disputes, maintain security, or support church administration.

Direct messages and community posts are designed in the repository to expire after approximately 30 days unless changed in production configuration. Community stories are designed to expire after approximately 24 hours.

Attendance, finance, audit, church administration, role assignment, support, and safeguarding-related records may be retained longer because churches may need them for accountability, reporting, accounting, security, or legal reasons.

Prayer and counseling records should be retained only as long as needed for pastoral care, church policy, legal compliance, or safeguarding obligations. Each church should define a retention period for these sensitive records.

Backups, logs, and third-party provider systems may retain data for a limited additional period after deletion from the live app. Where deletion is requested, we will take reasonable steps to delete or de-identify data unless retention is required or permitted by law.

15. Account deletion and data deletion requests

You may request deletion of your Grace Connect account and associated personal data by using the in-app account deletion request feature where available or by contacting [privacy contact / deletion request URL].

Because Grace Connect is connected to church administration, some records may need to be retained after account deletion, such as audit logs, finance records, attendance records, safeguarding records, legal records, security logs, or records required by the church. Where retention is required, access will be limited and the data will be retained only for the stated purpose.

Important implementation note: the reviewed repository contains a Delete Account option that currently signs the user out rather than fully deleting the Supabase account and associated records. Before launch, the app operator should implement a secure deletion workflow using a trusted server-side process and should publish an external deletion request URL if the app is distributed through Google Play.

16. Security measures

Grace Connect uses Supabase authentication, email verification, session checks, route guards, row-level security, role-based permissions, server-side database functions, church isolation, audit logging, content reports, blocking, and permission checks to protect user data.

Data transmitted to backend services should be protected using HTTPS/TLS. Supabase states that customer data is encrypted at rest with AES-256 and in transit via TLS. Firebase services are subject to Google's privacy and security controls.

No system is perfectly secure. You are responsible for protecting your password, device, email account, and account access. Do not share confidential information through the app unless you understand who can access it.

17. International transfers

The app, Supabase, Firebase/Google, email providers, notification providers, map services, support tools, and giving providers may process or store information in countries outside Jamaica or outside your country of residence.

By using Grace Connect, you understand that your information may be transferred, stored, and processed in other countries where privacy laws may differ. We use service providers that publish privacy, security, and data processing terms, and we take reasonable steps to protect information transferred through those providers.

18. Children and youth

Grace Connect may be used by churches that serve families, children, youth ministries, and family-tree features. The app is not intended for unsupervised use by children where parental or guardian consent is required by applicable law or church policy.

If a church enters or manages information about a minor, the church is responsible for obtaining appropriate consent, limiting access, and using the information only for legitimate church, safety, ministry, or administrative purposes.

Parents or guardians may contact the privacy contact or the relevant church administrator to request access, correction, or deletion of a minor's information where applicable.

19. Third-party links and services

Grace Connect may link to external websites, livestreams, giving pages, maps, YouTube videos, web pages, or third-party resources. When you leave Grace Connect, the third-party service's privacy policy and terms apply.

We are not responsible for the privacy, security, content, or practices of third-party websites or services. Review their policies before submitting personal or payment information.

20. Changes to this policy

We may update this Privacy Policy from time to time to reflect changes in the app, law, service providers, or church operations. The Effective Date above will show when the policy was last updated.

If a change materially affects how personal information is collected, used, shared, or retained, we will provide notice in the app, by email, through the website, or by another appropriate method where required.

21. Contact us

For privacy questions, account deletion requests, data access requests, correction requests, or complaints, contact:

Grace Connect Privacy Contact: [privacy email address]

Church Administrator: [church-specific contact if applicable]

Developer / Operator Contact: [developer or company contact]

If you are in Jamaica and believe your personal data rights have not been respected, you may also contact the Office of the Information Commissioner, Jamaica, or use any complaint process available under applicable data-protection law.

6. Google Play Data Safety and App Store Disclosure Checklist

App-store warning

The app requests sensitive permissions including location, background location, microphone/audio recording, notifications, and media/file access through pickers. App-store disclosure forms must match the production build, not only this draft policy.

Disclosure category	What to declare / verify
Personal info	Name, email, phone number, address/parish/city, profile photo, social links, biography, church role, membership status
Religious/community data	Church membership, prayer requests, counseling requests, attendance, ministry/study group participation, testimonies, family relationships
Location	Precise/approximate/background location for geofence attendance and church location setup
Photos/videos/audio/files	Profile photos, cover photos, chat images/videos, voice messages, story media, support screenshots/attachments
Messages and user content	Direct messages, group messages, posts, comments, stories, testimonies, reports, reactions, likes
Financial information	External giving provider may collect payment data. App may store transaction/receipt records if finance module used
Device and app info	OS, device model/brand/name, app version, build number, FCM token, crash/log/diagnostic data where enabled
Sharing with service providers	Supabase, Firebase/Google, email/support providers, map providers, external giving providers, analytics providers where enabled
Security practices	HTTPS/TLS, Supabase Auth, email verification, RLS, RBAC, audit logs, church isolation, content reporting, blocking
Deletion	Implement real server-side deletion workflow and external deletion request URL before store publication

7. Source Evidence and Review Notes

- Application identity and dependencies: pubspec.yaml identifies Grace Connect as a church management system and lists Supabase, Firebase, messaging, location, notifications, maps, media, audio, and storage-related packages.
- Authentication: lib/main.dart, auth_flow_service.dart, auth_required.dart, signup_screen.dart, login_screen.dart.
- Profiles and privacy: user_profile.dart, complete_profile_screen.dart, account_settings_screen.dart, privacy_settings_screen.dart, profile_service.dart.
- RLS/RBAC: Supabase migration files for signup/family/feed fixes, role/events/prayer/admin, messages/testimonies/groups hardening, chat/feed safety/vanishing, and later fixes.
- Attendance/location: AndroidManifest.xml and attendance_service.dart.
- Messaging/moderation: direct_message_service.dart, moderation_service.dart, direct message migrations, user blocks, content reports, cleanup functions.
- Giving/finance: donations_screen.dart, finance_service.dart, transaction_model.dart.
- Support/diagnostics: support_screen.dart and related support ticket model/email service logic.
- Notifications: notification_service.dart and functions/index.js.

8. Legal and Vendor Reference Notes

- Jamaica: The Office of the Information Commissioner, Jamaica publishes Data Protection Act resources, data-controller registration information, complaint/breach reporting options, data protection standards, and contact details.
- Supabase: Supabase publishes security and privacy materials describing encryption in transit and at rest, SOC 2 Type 2, ISO 27001, MFA, role-based access controls, and customer-data processing responsibilities.
- Firebase/Google: Firebase publishes privacy and security information describing customer/controller responsibilities, Google/Firebase processor roles, data-processing terms, ISO/SOC compliance, Cloud Messaging, Authentication, Cloud Functions, and international transfer information.
- Google Play: Google requires privacy-policy and Data Safety disclosures that accurately describe personal and sensitive data access, collection, use, sharing, security practices, retention, and deletion. It also requires account-deletion request mechanisms when an app allows account creation.